

Informe Técnico – Requisitos del Sistema de Autenticación y Autorización con Roles Básicos

Descripción General del Producto

El sistema a desarrollar consiste en una aplicación web orientada a la gestión de contenido en un blog, que incluye funcionalidades diferenciadas según el rol del usuario. El producto debe permitir a los usuarios registrarse, iniciar sesión de forma segura y, una vez autenticados, acceder a funcionalidades específicas según su perfil: **Administrador** o **Usuario común**.

Este sistema debe garantizar la integridad, confidencialidad y correcta gestión de los accesos, estableciendo una separación clara de responsabilidades entre usuarios autenticados con distintos niveles de privilegio.

Especificaciones Funcionales

Módulo de Registro de Usuarios

- La aplicación debe proveer una interfaz para registrar nuevos usuarios mediante nombre de usuario y contraseña.
- El sistema debe almacenar las contraseñas de forma segura utilizando una función de hashing criptográficamente robusta (bcrypt, argon2 o equivalente).
- Al momento del registro, los usuarios deben recibir por defecto el rol de “Usuario común”.
- El proceso de registro debe validar que no se repitan nombres de usuario ya existentes y asegurar la integridad de los datos ingresados.

Módulo de Autenticación

- Debe existir un mecanismo de inicio de sesión mediante ingreso de nombre de usuario y contraseña.
- El sistema debe validar las credenciales contra los registros almacenados y autenticar al usuario solo si la verificación es exitosa.
- Una vez autenticado, el usuario debe ser redirigido a una vista protegida que represente su espacio principal.

- Usuarios no autenticados no deben poder acceder a rutas o recursos internos del sistema.

Gestión de Roles y Permisos

- El sistema debe contemplar dos roles diferenciados:
 - **Administrador:** con privilegios de lectura, edición, creación y eliminación de publicaciones.
 - **Usuario común:** con privilegios exclusivamente de lectura de publicaciones.
- El rol asignado debe determinar el conjunto de acciones que el usuario puede ejecutar dentro del sistema.
- Solo el usuario con rol de Administrador debe tener capacidad para cambiar el rol de otros usuarios, ya sea desde la base de datos o mediante un panel interno si se implementa.

Control de Acceso

- El acceso a funcionalidades específicas debe estar condicionado al rol del usuario:
 - Usuarios con rol “Administrador” deben poder gestionar todo el contenido del blog, incluyendo la creación de nuevas entradas, modificación de publicaciones existentes y eliminación de registros.
 - Usuarios con rol “Usuario común” deben estar limitados a la visualización de las publicaciones disponibles.
- El sistema debe validar el rol del usuario en cada solicitud a rutas protegidas, ya sea mediante middleware o lógica de validación en el backend.
- Cualquier intento de acceso no autorizado debe ser rechazado y devuelto con un estado HTTP correspondiente (403 Forbidden).

Seguridad y Protección de Datos

- Las contraseñas deben almacenarse exclusivamente como hashes, con salting adecuado.
- La autenticación debe protegerse mediante sesión segura o tokens (según la implementación elegida).
- El sistema debe garantizar que solo usuarios autenticados puedan acceder a contenidos del blog.
- Se debe evitar la exposición de datos sensibles en respuestas del servidor o mensajes de error.

Validación y Pruebas

- El sistema debe ser probado con múltiples escenarios, incluyendo:
 - Flujo completo de registro y login para nuevos usuarios.
 - Acceso correcto a funcionalidades según el rol asignado.
 - Restricción efectiva de funcionalidades administrativas para usuarios comunes.
 - Rechazo de intentos de login con credenciales inválidas.
- Las pruebas deben incluir tanto el comportamiento funcional como los mecanismos de seguridad (validación de hashing, control de sesión, acceso indebido a rutas, etc.).